



Lecture Notes

Institute Name:	Silver Oak College of Computer Application		
Programme Name:	Master of Science Data Science	Semester:	1
Course Code:	DSM5061C	Course Name:	Information and Data Security
Unit No.:	1	Unit Name:	Foundations of Information and Data Security

Prerequisite:

1. Basic Computer Fundamentals

Point	Definition / Description
Computer	An electronic device that accepts data, processes it according to instructions, stores it, and produces meaningful information.
Data	Raw facts and figures entered into a computer for processing.
Information	Processed data that is meaningful and useful for decision-making.
Hardware	Physical components of a computer that can be seen and touched, such as the keyboard, monitor, CPU, and printer.
Software	A collection of programs and instructions that enable the computer to perform specific tasks.
Input Devices	Hardware used to enter data into a computer, such as a keyboard, mouse, scanner, and microphone.
CPU (Central Processing Unit)	The brain of the computer that performs calculations, executes instructions, and controls all operations.
Memory	Storage area used to store data, programs, and information temporarily or permanently.
Output Devices	Hardware used to display or produce processed information, such as monitors, printers, and speakers.
Operating System	System software that manages computer hardware, software resources, and provides an interface between the user and the computer.

2. Fundamentals of Information Technology

Point	Definition / Description
Information Technology (IT)	The use of computers, software, networks, and communication technologies to collect, process, store, secure, and share information.
Hardware	Physical equipment used in IT systems, including computers, servers, and networking devices.
Software	Programs and applications that perform specific functions on computer systems.
Database	An organized collection of related data that allows efficient storage, retrieval, and management.
Networking	The process of connecting computers and devices to exchange information and resources.
Internet	A worldwide network of interconnected computers used for communication and information sharing.
Cloud Computing	Delivery of computing services such as storage, software, and processing over the Internet.
Artificial Intelligence (AI)	Technology that enables machines to simulate human intelligence and decision-making.
Big Data	Extremely large datasets that require advanced tools and techniques for storage and analysis.
Cybersecurity	The practice of protecting computer systems, networks, and data from cyber threats and unauthorized access.

3. Basic Knowledge of Computer Networks and Internet Technologies

Point	Definition / Description
Computer Network	A group of interconnected computers and devices that communicate and share resources.
PAN (Personal Area Network)	A network connecting personal devices within a short distance, such as Bluetooth devices.
LAN (Local Area Network)	A network that connects computers within a limited area like a home, office, or college campus.

MAN (Metropolitan Area Network)	A network that covers a city or metropolitan region.
WAN (Wide Area Network)	A network connecting computers over large geographical areas; the Internet is the largest WAN.
Hub	A networking device that sends incoming data to all connected devices.
Switch	A networking device that forwards data only to the intended destination device.
Router	A device that connects multiple networks and directs data between them.
Modem	A device that converts digital signals to analogue signals and vice versa for Internet communication.
Firewall	A security device or software that monitors and controls incoming and outgoing network traffic.
Internet	The global system of interconnected computer networks used for communication and information exchange.
Web Browser	Software used to access and display web pages, such as Google Chrome and Microsoft Edge.
Search Engine	An online service that helps users locate information on the Internet, such as Google and Bing.
IP Address	A unique numerical identifier assigned to each device connected to a network.
TCP/IP	A standard communication protocol suite used for transmitting data over the Internet.
HTTP/HTTPS	Protocols used for transferring web pages, with HTTPS providing secure communication.
FTP	File Transfer Protocol used for transferring files between computers over a network.
DNS	Domain Name System that translates domain names into IP addresses.

4. Familiarity with Data Handling and Database Concepts

Point	Definition /Description
Data	Raw facts and figures that have not yet been processed into meaningful information.
Information	Processed and organized data that is useful for understanding and decision-making.
Data Handling	The process of collecting, storing, organizing, processing, analysing, and presenting data.
Database	An organized collection of related data stored electronically for easy access and management.
DBMS (Database Management System)	Software used to create, manage, retrieve, update, and secure databases.
Table	A collection of related data organized into rows and columns.
Record (Row)	A complete set of related information stored in a single row of a table.
Field (Column)	A single attribute or category of data represented by a column in a table.
Primary Key	A field that uniquely identifies each record in a database table.
Foreign Key	A field used to establish a relationship between two database tables.
SQL (Structured Query Language)	A standard language used to create, retrieve, update, and manage data in relational databases.
Data Redundancy	Unnecessary duplication of data within a database.
Data Integrity	Ensuring that data remains accurate, consistent, and reliable throughout its lifecycle.
Data Security	Protection of data from unauthorized access, modification, disclosure, or destruction.
Backup and Recovery	Techniques used to create copies of data and restore it in case of data loss or system failure.



Unit : 1 Foundations of Information and Data Security

1. Introduction to Information and Data Security

Definition

Information Security (InfoSec) is the practice of protecting information and information systems from unauthorized access, use, disclosure, modification, disruption, or destruction. It ensures that valuable information remains secure throughout its lifecycle.

Data Security is a subset of information security that focuses specifically on protecting digital and physical data from unauthorized access, corruption, theft, or accidental loss.

Information Security = Protection of all information (digital, printed, verbal, etc.)
Data Security = Protection of data stored, processed, or transmitted electronically or physically.

Objectives of Information Security

The primary objectives are based on the CIA Triad:

1. Confidentiality

Confidentiality ensures that information is accessible only to authorized individuals.

Examples

- Password protection
- Encryption
- Multi-Factor Authentication (MFA)
- Access control mechanisms

Real-life Example

Only the HR department can access employee salary records.

2. Integrity

Integrity ensures that information remains accurate, complete, and unaltered.

Examples

- Hashing
- Digital Signatures
- Checksums
- Version Control



Real-life Example

A student's examination marks cannot be modified without proper authorization.

3. Availability

Availability ensures that authorized users can access information whenever required.

Examples

- Data Backup
- Disaster Recovery
- Cloud Storage
- Redundant Servers
- UPS Systems

Real-life Example

Online banking services remain available 24×7.

Additional Security Principles

Authentication

Verifies the identity of a user before granting access.

Examples

- Username and Password
- OTP
- Biometrics

Authorization

Determines what resources an authenticated user is allowed to access.

Example

A faculty member can update student marks but cannot modify salary records.

Accountability

Ensures that every user action can be traced using audit logs.

Example

Every login attempt is recorded with date, time, and IP address.

Non-Repudiation



Prevents users from denying actions they have performed.

Example

Digital signatures in online banking transactions.

Information vs Data Security

Information Security	Data Security
Protects all forms of information.	Protects stored and transmitted data.
Covers people, processes, and technology.	Focuses mainly on data protection technologies.
Includes policies and risk management.	Includes encryption, backup, and access control.
Broader concept.	Subset of Information Security.

2. Information Assets

Definition

An Information Asset is anything that stores, processes, transmits, or contains information that has value to an individual or organization and therefore requires protection.

Information assets are considered valuable because their loss, theft, or compromise can negatively impact business operations, reputation, finances, or legal compliance.

Characteristics of Information Assets

- Valuable to the organization.
- Supports business operations.
- Can exist in physical or digital form.
- Requires confidentiality, integrity, and availability.
- Must be protected throughout its lifecycle.

Types of Information Assets

1. Data Assets

Include all forms of organizational data.

Examples

- Customer records



- Employee information
- Financial records
- Medical records
- Student databases

2. Hardware Assets

Physical devices used to store or process information.

Examples

- Computers
- Servers
- Laptops
- Mobile phones
- Hard disks
- Network devices

3. Software Assets

Applications and operating systems used within the organization.

Examples

- Windows
- Linux
- MS Office
- ERP Systems
- Database Software

4. Network Assets

Communication infrastructure connecting systems.

Examples

- Routers
- Switches
- Firewalls
- Wireless Access Points
- VPN

5. Human Assets

People who create, process, or manage information.

Examples

- Employees
- Managers



- Students
- Customers
- IT Administrators

6. Intellectual Property

Original creations that provide competitive advantage.

Examples

- Research papers
- Source code
- Patents
- Copyrights
- Designs

7. Documentation

Organizational documents containing valuable information.

Examples

- Policies
- Contracts
- Reports
- Standard Operating Procedures (SOPs)

Asset Classification

Organizations classify information assets according to their sensitivity.

Classification	Description	Example
Public	Available to everyone	Company brochure
Internal	Used only within the organization	Internal notices
Confidential	Limited access	Employee records
Highly Confidential	Critical business information	Banking credentials, research data

3. Security Challenges in Data-Driven Organizations

Definition



A Data-Driven Organization uses data to support decision-making, improve business operations, predict trends, and provide better customer services.

Since these organizations handle massive volumes of sensitive information, they face numerous security challenges.

Major Security Challenges

1. Data Breaches

Unauthorized access to confidential information.

Causes

- Weak passwords
- Poor security configuration
- Insider threats
- Hacking

Impact

- Financial loss
- Reputation damage
- Legal penalties

2. Malware Attacks

Malicious software designed to damage systems or steal information.

Types

- Virus
- Worm
- Trojan Horse
- Spyware
- Ransomware

3. Phishing Attacks

Cybercriminals trick users into revealing confidential information.

Examples

- Fake banking emails
- Fake login pages
- SMS fraud
- Social media scams

4. Insider Threats

Security risks caused by employees, contractors, or business partners.

Types

- Intentional
- Accidental
- Negligent

5. Weak Passwords

Simple or reused passwords increase the risk of unauthorized access.

Examples

- 123456
- password
- qwerty

6. Cloud Security Risks

Data stored in cloud environments may be exposed due to:

- Misconfigured cloud storage
- Weak authentication
- Poor access control
- Insecure APIs

7. Internet of Things (IoT) Vulnerabilities

IoT devices often lack strong security mechanisms.

Examples

- Smart cameras
- Smart TVs
- Wearable devices
- Smart sensors

8. Social Engineering

Attackers manipulate people instead of technology.

Methods

- Phone calls
- Fake emails
- Fake websites
- Impersonation

9. Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS)



Attackers overwhelm servers with excessive requests, making services unavailable.

Examples

- Online shopping websites
- Banking applications
- Government portals

10. Data Privacy Issues

Improper handling of personal information may violate privacy laws.

Examples

- Unauthorized data sharing
- Data leakage
- Excessive data collection

Consequences of Security Incidents

- Financial losses
- Operational disruption
- Loss of customer trust
- Legal action and regulatory penalties
- Theft of intellectual property
- Damage to organizational reputation

4. Importance of Information Security

Definition

Information Security is essential for protecting organizational information from cyber threats while ensuring business continuity, customer trust, and legal compliance.

Importance of Information Security

1. Protects Confidential Information

Prevents unauthorized users from accessing sensitive information such as customer records, employee data, and financial information.

2. Ensures Data Integrity

Maintains the accuracy and consistency of data by preventing unauthorized modification.

3. Maintains Business Continuity



Reduces downtime caused by cyberattacks, hardware failures, or natural disasters through backup and disaster recovery mechanisms.

4. Builds Customer Trust

Customers are more likely to trust organizations that safeguard their personal and financial information.

5. Prevents Financial Loss

Reduces losses associated with cyberattacks, fraud, legal claims, and recovery costs.

6. Supports Legal and Regulatory Compliance

Organizations must comply with applicable data protection and cybersecurity regulations to avoid penalties.

7. Protects Intellectual Property

Safeguards valuable organizational assets such as research, patents, software, and business strategies.

8. Prevents Cyber Attacks

Implements preventive controls such as firewalls, antivirus software, encryption, and intrusion detection systems to reduce security risks.

9. Enhances Organizational Reputation

Strong information security practices improve public confidence and strengthen the organization's reputation.

10. Enables Secure Digital Transformation

Supports the safe adoption of cloud computing, artificial intelligence, big data analytics, e-commerce, mobile applications, and remote working environments.

Best Practices for Information Security

- Use strong and unique passwords.
- Enable Multi-Factor Authentication (MFA).
- Encrypt sensitive information.
- Install and regularly update antivirus software.
- Apply operating system and software security patches.
- Perform regular data backups.
- Restrict access using the principle of least privilege.
- Educate users about phishing and social engineering attacks.
- Monitor systems continuously using security logs and alerts.
- Develop and test an incident response and disaster recovery plan.

Key Takeaways

- Information Security protects all forms of information, while Data Security specifically protects stored and transmitted data.
- Information assets include data, hardware, software, networks, people, intellectual property, and documentation.
- Data-driven organizations face evolving threats such as malware, phishing, insider attacks, cloud risks, and data breaches.
- The CIA Triad—Confidentiality, Integrity, and Availability—forms the foundation of information security.
- Effective information security is critical for protecting organizational assets, ensuring compliance, maintaining customer trust, and enabling secure digital operations.

2. Introduction to Core Security Principles

Definition

The Core Security Principles are the fundamental concepts of Information Security that ensure information and information systems remain secure, reliable, and available. These principles are collectively known as the CIA Triad, which stands for:

- C – Confidentiality
- I – Integrity
- A – Availability

The CIA Triad provides the foundation for designing, implementing, and managing secure information systems. Every security policy, technology, and control aims to achieve these three objectives.

CIA Triad

The CIA Triad is a security model that helps organizations protect their information assets from unauthorized access, modification, and disruption.

Confidentiality

Definition

Confidentiality ensures that information is accessible only to authorized users and prevents unauthorized individuals from viewing or disclosing sensitive information.

The primary objective of confidentiality is to protect privacy and prevent information leakage.

Objectives

- Protect sensitive information.



- Prevent unauthorized access.
- Ensure user privacy.
- Maintain trust between organizations and users.

Methods to Achieve Confidentiality

- Password Protection
- Multi-Factor Authentication (MFA)
- Data Encryption
- User Authentication
- Access Control Lists (ACL)
- Role-Based Access Control (RBAC)
- Biometric Authentication
- Virtual Private Networks (VPN)

Examples

- Protecting online banking credentials.
- Restricting access to employee salary records.
- Encrypting customer information.
- Password-protected email accounts.

Real-World Applications

Banking

Only account holders and authorized bank employees can access account details.

Healthcare

Doctors and authorized medical staff can access patient medical records.

Education

Only students and faculty members can access examination results through the university portal.

Government

Confidential government documents are accessible only to authorized officials.

Consequences of Poor Confidentiality

- Identity theft
- Financial fraud
- Data breaches
- Privacy violations
- Reputation loss



- Legal penalties

Integrity

Definition

Integrity ensures that information remains accurate, complete, consistent, and unaltered throughout its lifecycle.

Only authorized users should be able to modify data.

Objectives

- Maintain data accuracy.
- Prevent unauthorized modification.
- Detect data tampering.
- Ensure trustworthy information.

Methods to Achieve Integrity

- Hash Functions (SHA-256, SHA-3)
- Digital Signatures
- Checksums
- Version Control
- Audit Logs
- Database Constraints
- Access Permissions

Examples

- Student marks cannot be modified without authorization.
- Financial transaction records remain unchanged.
- Medical prescriptions cannot be altered illegally.

Real-World Applications

Banking

Transaction amounts remain unchanged after payment.

Online Shopping

Order details cannot be modified after successful payment.

Healthcare

Electronic medical records remain accurate throughout patient treatment.



University Systems

Student grades are updated only by authorized faculty members.

Consequences of Poor Integrity

- Incorrect financial reports
- False medical information
- Fraudulent transactions
- Data corruption
- Loss of trust

Availability

Definition

Availability ensures that information, applications, and services are accessible to authorized users whenever they are needed.

A secure system is useful only if it is available when required.

Objectives

- Minimize downtime.
- Ensure continuous business operations.
- Provide uninterrupted services.
- Support disaster recovery.

Methods to Achieve Availability

- Regular Data Backup
- Disaster Recovery Plan
- Cloud Computing
- Redundant Servers
- UPS (Uninterruptible Power Supply)
- Load Balancing
- Failover Systems
- Network Monitoring

Examples

- Internet banking available 24×7.
- Hospital information systems accessible at all times.
- Online learning portals available during examinations.

Real-World Applications



Banking

ATM services remain available even during peak hours.

Cloud Services

Cloud platforms ensure continuous access to applications and data.

E-Commerce

Online shopping websites remain operational during festivals and sales.

Emergency Services

Police, ambulance, and hospital systems remain available throughout the day.

Consequences of Poor Availability

- Service interruptions
- Financial losses
- Customer dissatisfaction
- Business downtime
- Reduced productivity

Comparison of CIA Triad

Security Principle	Definition	Main Objective	Common Security Controls	Example
Confidentiality	Protects information from unauthorized access.	Privacy	Passwords, Encryption, MFA, Access Control	Only HR staff can access employee salary records.
Integrity	Ensures data remains accurate and unchanged.	Accuracy	Hashing, Digital Signatures, Audit Logs	Student marks cannot be modified without authorization.
Availability	Ensures systems and data are accessible when required.	Accessibility	Backup, Disaster Recovery, Redundant Servers	Internet banking services available 24×7.



Real-World Applications of the CIA Triad

1. Online Banking

Confidentiality

- Customer login credentials are protected using encryption and MFA.

Integrity

- Transaction records cannot be modified after completion.

Availability

- Banking services remain available 24×7 through ATMs, mobile apps, and internet banking.

2. Hospital Information System

Confidentiality

- Only authorized doctors and nurses can access patient records.

Integrity

- Medical reports remain accurate and cannot be altered without authorization.

Availability

- Patient records are accessible during emergencies.

3. E-Commerce Websites

Confidentiality

- Customer payment details are encrypted using HTTPS.

Integrity

- Product prices and order information remain accurate.

Availability

- Shopping websites remain operational during high-traffic sales events.

4. University Management System

Confidentiality



- Student personal information is accessible only to authorized users.

Integrity

- Examination results can only be updated by faculty members.

Availability

- Students can access the portal anytime to view attendance, results, and course materials.

5. Cloud Computing Services

Confidentiality

- Cloud data is protected using encryption and identity management.

Integrity

- Files remain accurate through version control and integrity checks.

Availability

- Cloud services provide continuous access through redundant data centres and failover mechanisms.

Importance of the CIA Triad

- Protects sensitive organizational information.
- Ensures data accuracy and reliability.
- Provides uninterrupted access to information systems.
- Reduces the risk of cyberattacks and data breaches.
- Helps organizations comply with legal and regulatory requirements.
- Builds customer trust and confidence.
- Supports secure digital transformation and cloud adoption.
- Protects financial, healthcare, educational, and government information systems.

Summary

- The CIA Triad is the cornerstone of information security.
- Confidentiality protects information from unauthorized access.
- Integrity ensures information remains accurate and unaltered.
- Availability ensures information and services are accessible whenever needed.
- Together, these three principles guide the design of secure systems and are applied across banking, healthcare, education, e-commerce, cloud computing, and government sectors to protect information assets and ensure secure, reliable operations.



Threat and Risk Management

Threat and Risk Management is the process of identifying, analysing, evaluating, and controlling threats and risks that may affect an organization's information assets. It helps organizations protect data, systems, networks, and business operations from cyber attacks, accidental damage, and natural disasters.

Threats

Definition

A Threat is any event, action, or circumstance that has the potential to exploit a vulnerability and cause harm to information systems, networks, or data. Threats may be intentional, accidental, or natural.

Types of Threats

Malware

Malicious software designed to damage systems or steal information.

Examples

- Virus
- Worm
- Trojan Horse
- Ransomware
- Spyware
- Adware

Phishing

A fraudulent attempt to obtain sensitive information by pretending to be a trustworthy entity through emails, messages, or fake websites.

Examples

- Fake banking emails
- Fake login pages
- SMS scams (Smishing)
- Voice scams (Vishing)

Insider Threat

A security threat originating from employees, contractors, or other trusted individuals.

Types

- Malicious Insider



- Negligent Insider
- Accidental Insider

Denial-of-Service (DoS/DDoS)

An attack that floods a server or network with excessive traffic, making services unavailable to legitimate users.

Social Engineering

A technique in which attackers manipulate people into revealing confidential information instead of exploiting technical vulnerabilities.

Examples

- Impersonation
- Shoulder Surfing
- Tailgating
- Fake Technical Support Calls

Physical Threats

Threats that damage or destroy physical infrastructure.

Examples

- Fire
- Flood
- Theft
- Earthquake
- Power Failure

Characteristics of Threats

- May originate from internal or external sources.
- Can be intentional or accidental.
- Exploit system vulnerabilities.
- Affect confidentiality, integrity, and availability.
- Can cause financial, operational, and reputational damage.

Vulnerabilities

Definition

A Vulnerability is a weakness or flaw in hardware, software, networks, or organizational processes that can be exploited by a threat.

A threat becomes dangerous only when it can exploit a vulnerability.

Types of Vulnerabilities

Technical Vulnerabilities

- Weak passwords
- Software bugs
- Outdated operating systems
- Unpatched software
- Misconfigured firewalls

Human Vulnerabilities

- Lack of cybersecurity awareness
- Sharing passwords
- Clicking suspicious links
- Poor password management

Physical Vulnerabilities

- Unlocked server rooms
- Lack of CCTV surveillance
- Poor physical security
- Stolen laptops or USB drives

Examples of Vulnerabilities

- Using "123456" as a password.
- Running outdated antivirus software.
- Leaving computers unlocked.
- Failure to install security updates.

Risks

Definition

A Risk is the possibility that a threat will exploit a vulnerability and cause damage to an organization's assets.

Relationship

Threat + Vulnerability = Risk

Types of Risks

Cyber Risk

Risk arising from cyber attacks.



Examples

- Malware
- Hacking
- Data theft

Operational Risk

Risk caused by failures in business processes or systems.

Examples

- Human error
- System failure

Financial Risk

Risk resulting in financial losses.

Examples

- Fraud
- Business interruption
- Regulatory fines

Reputational Risk

Risk that damages the organization's reputation.

Examples

- Data breach
- Negative publicity
- Customer complaints

Compliance Risk

Risk of violating legal, regulatory, or industry requirements.

Examples

- Non-compliance with data protection laws
- Failure to implement security policies

Risk Formula

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$$

Attack Surface



Definition

The Attack Surface is the total number of possible entry points through which an attacker can gain unauthorized access to an organization's systems or data.

A larger attack surface increases the chances of successful cyber attacks.

Types of Attack Surface

Digital Attack Surface

Includes internet-connected systems.

Examples

- Websites
- Mobile Applications
- Email Servers
- Cloud Services
- APIs

Physical Attack Surface

Includes physical devices and facilities.

Examples

- Servers
- Laptops
- USB Drives
- Office Buildings

Human Attack Surface

Includes users whose actions may expose the organization to attacks.

Examples

- Weak passwords
- Falling victim to phishing
- Sharing confidential information

Methods to Reduce the Attack Surface

- Disable unused services.
- Remove unnecessary software.
- Apply security patches.
- Enable Multi-Factor Authentication.
- Limit user privileges.
- Encrypt sensitive information.



- Conduct cybersecurity awareness training.

Data Breaches

Definition

A Data Breach is a security incident in which confidential, sensitive, or protected information is accessed, disclosed, copied, altered, or stolen without authorization.

Causes of Data Breaches

- Weak passwords
- Malware attacks
- Insider threats
- Phishing attacks
- Software vulnerabilities
- Cloud misconfigurations
- Lost or stolen devices

Effects of Data Breaches

- Financial losses
- Identity theft
- Business disruption
- Legal penalties
- Reputation damage
- Loss of customer trust

Real-World Examples

Banking

- Theft of customer account information.

Healthcare

- Unauthorized access to patient records.

Education

- Leakage of student examination records.

E-Commerce

- Theft of customer payment information.

Prevention of Data Breaches

- Use strong passwords.



- Enable Multi-Factor Authentication.
- Encrypt sensitive data.
- Regularly update software.
- Monitor system activities.
- Perform regular backups.
- Train employees on cybersecurity awareness.

Risk Assessment Basics

Definition

Risk Assessment is the systematic process of identifying, analysing, evaluating, and prioritizing security risks so that appropriate controls can be implemented to reduce their impact.

Objectives of Risk Assessment

- Identify valuable assets.
- Identify threats.
- Identify vulnerabilities.
- Evaluate the likelihood of attacks.
- Estimate the impact of security incidents.
- Recommend suitable security controls.

Risk Assessment Process

Asset Identification

Identify information assets that require protection.

Examples

- Customer Database
- Financial Records
- Servers
- Network Devices

Threat Identification

Determine possible threats that may affect assets.

Examples

- Hackers
- Malware
- Fire
- Flood

Vulnerability Identification

Identify weaknesses in systems or processes.

Examples

- Weak passwords
- Outdated software
- Poor access control

Risk Analysis

Estimate the likelihood of a threat exploiting a vulnerability and determine its potential impact.

Risk Evaluation

Prioritize risks according to their severity.

Risk Level	Description
Low	Low probability and low impact.
Medium	Moderate probability or impact.
High	High probability and significant impact.
Critical	Very high impact requiring immediate action.

Risk Treatment

Implement controls to reduce identified risks.

Examples

- Firewalls
- Antivirus Software
- Encryption
- Access Control
- Security Awareness Training

Continuous Monitoring

Regularly review risks and monitor systems to ensure security controls remain effective.

Relationship Between Threat, Vulnerability, and Risk

Component	Definition	Example
-----------	------------	---------

Threat	A potential event that can cause harm to an information asset.	Hacker, Malware, Phishing
Vulnerability	A weakness that can be exploited by a threat.	Weak Password, Unpatched Software
Risk	The likelihood that a threat will exploit a vulnerability and cause damage.	Hacker exploiting a weak password to access customer data.

Example Scenario

A company stores customer information on an outdated web server.

- Asset: Customer Database
- Threat: Hacker
- Vulnerability: Unpatched Web Server
- Risk: Theft of customer data
- Impact: Financial loss, legal penalties, and reputational damage
- Mitigation: Install security updates, enable firewalls, implement Multi-Factor Authentication, and continuously monitor network activity.

Best Practices for Threat and Risk Management

- Conduct regular risk assessments.
- Keep software and operating systems updated.
- Use strong passwords and Multi-Factor Authentication (MFA).
- Install antivirus and anti-malware software.
- Encrypt sensitive information.
- Restrict access based on the principle of least privilege.
- Perform regular data backups.
- Educate employees on cybersecurity awareness.
- Monitor systems continuously using security tools.
- Develop and test incident response and disaster recovery plans.

Summary

- Threats are potential events that can cause harm to systems or data.
- Vulnerabilities are weaknesses that attackers can exploit.
- Risks arise when threats exploit vulnerabilities and cause damage.
- The Attack Surface represents all possible entry points available to attackers.
- A Data Breach involves unauthorized access to sensitive information.
- Risk Assessment is the process of identifying, analysing, evaluating, and treating risks to protect organizational information assets and ensure secure business operations.



Human-Centric Security

Introduction

Human-Centric Security is an approach to information security that focuses on protecting people, their behaviour, and their interactions with technology. While organizations invest in advanced security technologies such as firewalls, encryption, and antivirus software, human error remains one of the leading causes of security incidents. Human-centric security aims to educate users, promote security awareness, and reduce risks caused by human actions.

Objectives of Human-Centric Security

- Protect users from cyber threats.
- Increase cybersecurity awareness.
- Reduce human errors that lead to security incidents.
- Encourage safe online behaviour.
- Prevent unauthorized access to information.
- Strengthen the overall security posture of an organization.

Social Engineering

Definition

Social Engineering is a cyberattack technique in which attackers manipulate, deceive, or influence people into revealing confidential information or performing actions that compromise security.

Unlike technical attacks, social engineering targets human psychology rather than computer systems.

Characteristics of Social Engineering

- Exploits human trust and emotions.
- Targets individuals rather than systems.
- Uses deception and manipulation.
- Often difficult to detect.
- Can result in financial and data loss.

Common Types of Social Engineering

Phishing

Sending fake emails or messages to trick users into revealing sensitive information.

Pretexting

Creating a fake identity or scenario to obtain confidential information.



Example

A person pretending to be an IT support engineer asking for login credentials.

Baiting

Offering something attractive to tempt victims into compromising security.

Example

A malicious USB drive labelled "Salary Details" left in an office.

Tailgating

An unauthorized person enters a restricted area by following an authorized employee.

Shoulder Surfing

Watching someone enter passwords or confidential information.

Quid Pro Quo

Offering a service or reward in exchange for sensitive information.

Example

A fake technical support representative offering free software assistance.

Prevention of Social Engineering

- Verify the identity of unknown individuals.
- Never share passwords or OTPs.
- Be cautious of unexpected emails or phone calls.
- Lock computers when unattended.
- Attend regular cybersecurity awareness training.
- Report suspicious activities immediately.

Phishing

Definition

Phishing is a cyberattack in which attackers impersonate trusted organizations or individuals to steal sensitive information such as usernames, passwords, banking details, or personal information.

Characteristics of Phishing

- Uses fake emails, websites, or messages.



- Creates a sense of urgency or fear.
- Requests confidential information.
- Often contains suspicious links or attachments.

Types of Phishing

Email Phishing

Fraudulent emails pretending to come from trusted organizations.

Spear Phishing

A targeted phishing attack aimed at a specific individual or organization.

Whaling

Phishing attacks targeting senior executives or high-profile individuals.

Smishing

Phishing attacks conducted through SMS messages.

Vishing

Phishing attacks conducted through voice calls.

Example of a Phishing Attack

A user receives an email claiming to be from a bank stating:

"Your account has been suspended. Click here immediately to verify your account."

The link directs the user to a fake banking website where login credentials are stolen.

Warning Signs of Phishing

- Unknown sender.
- Poor grammar or spelling.
- Urgent requests for immediate action.
- Suspicious links.
- Unexpected attachments.
- Requests for passwords or OTPs.

Prevention of Phishing

- Verify email addresses carefully.
- Do not click unknown links.



- Enable Multi-Factor Authentication (MFA).
- Keep antivirus software updated.
- Report suspicious emails.
- Use spam filters.
- Never share passwords or OTPs.

Identity Theft

Definition

Identity Theft is the unauthorized acquisition and use of another person's personal information for fraudulent or criminal purposes.

Attackers may steal personal data to impersonate victims and commit financial or cyber crimes.

Information Commonly Stolen

- Full Name
- Date of Birth
- Aadhaar Number
- PAN Number
- Passport Details
- Credit/Debit Card Information
- Bank Account Details
- Login Credentials
- Email Address
- Mobile Number

Causes of Identity Theft

- Phishing attacks
- Data breaches
- Weak passwords
- Social engineering
- Lost or stolen devices
- Public Wi-Fi attacks
- Malware infections

Consequences of Identity Theft

- Financial loss.
- Unauthorized bank transactions.
- Damage to personal reputation.
- Loss of privacy.
- Criminal misuse of personal identity.

Prevention of Identity Theft

- Use strong and unique passwords.
- Enable Multi-Factor Authentication.
- Avoid sharing personal information unnecessarily.
- Monitor bank statements regularly.
- Protect identity documents.
- Use secure websites (HTTPS).
- Avoid public Wi-Fi for sensitive transactions.
- Install antivirus software.

Insider Threats

Definition

An Insider Threat is a security risk that originates from individuals within an organization who have authorized access to systems, data, or facilities.

Insider threats may be intentional or accidental.

Types of Insider Threats

Malicious Insider

An employee intentionally steals or damages organizational information.

Example

An employee copies confidential customer data before leaving the company.

Negligent Insider

An employee unintentionally compromises security through careless behaviour.

Example

Sharing passwords or clicking phishing links.

Compromised Insider

An employee's account is taken over by cybercriminals.

Example

An attacker uses stolen login credentials to access company systems.

Causes of Insider Threats

- Weak password management.
- Lack of security awareness.
- Excessive user privileges.
- Employee dissatisfaction.
- Social engineering attacks.
- Poor monitoring.

Impact of Insider Threats

- Data leakage.
- Financial losses.
- Reputation damage.
- Operational disruption.
- Intellectual property theft.
- Legal and regulatory penalties.

Prevention of Insider Threats

- Apply the Principle of Least Privilege (PoLP).
- Conduct employee background verification.
- Provide regular cybersecurity awareness training.
- Monitor user activities through audit logs.
- Implement Role-Based Access Control (RBAC).
- Enforce strong password and MFA policies.
- Revoke access immediately when employees leave the organization.
- Develop an insider threat detection and response program.

Relationship Between Human-Centric Security Threats

Threat	Definition	Primary Target	Example
Social Engineering	Manipulating people to reveal confidential information or perform unsafe actions.	Human behaviour	Fake IT support requesting passwords.
Phishing	Fraudulent emails, messages, or websites designed to steal sensitive information.	User credentials	Fake bank email requesting login details.
Identity Theft	Unauthorized use of another person's personal information for fraud or crime.	Personal identity	Stolen Aadhaar or credit card information used fraudulently.
Insider Threat	Security risk originating from authorized individuals within an organization.	Internal systems and data	Employee leaking confidential company information.



Real-World Examples

Banking

- A customer receives a fake email requesting account verification (Phishing).
- Stolen banking credentials are used for unauthorized transactions (Identity Theft).

Healthcare

- A hospital employee accidentally emails patient records to the wrong recipient (Insider Threat).
- An attacker impersonates hospital IT staff to obtain login credentials (Social Engineering).

Education

- Students receive fake emails asking them to update university portal passwords (Phishing).
- A staff member shares examination records without authorization (Insider Threat).

Corporate Organizations

- Attackers leave infected USB drives in office premises hoping employees will connect them (Baiting).
- A former employee downloads confidential customer data before resignation (Malicious Insider).

Best Practices for Human-Centric Security

- Provide regular cybersecurity awareness and phishing simulation training.
- Verify the identity of individuals before sharing sensitive information.
- Use strong, unique passwords and enable Multi-Factor Authentication (MFA).
- Avoid clicking suspicious links or downloading unknown attachments.
- Protect personal and organizational information from unnecessary disclosure.
- Apply Role-Based Access Control (RBAC) and the Principle of Least Privilege (PoLP).
- Monitor user activities using audit logs and security monitoring tools.
- Report suspicious emails, phone calls, or activities immediately.
- Secure physical access to offices and restricted areas.
- Promote a security-aware culture where every employee understands their role in protecting information.

Summary

- Human-Centric Security focuses on protecting people as the first line of defence against cyber threats.

- Social Engineering manipulates individuals into revealing sensitive information or performing unsafe actions.
- Phishing uses fraudulent communications to steal credentials and personal information.
- Identity Theft involves the unauthorized use of personal information for fraudulent purposes.
- Insider Threats arise from trusted individuals who intentionally or unintentionally compromise organizational security.
- User awareness, strong authentication, access control, and continuous training are essential to reducing human-related cybersecurity risks.

Identity Protection

Introduction

Identity Protection is the process of safeguarding a user's digital identity from unauthorized access, misuse, theft, or impersonation. It involves verifying the identity of users, controlling access to resources, securing authentication credentials, and implementing advanced security mechanisms such as Multi-Factor Authentication (MFA).

Digital identity includes usernames, passwords, biometric information, email addresses, employee IDs, and other personal credentials used to access systems and online services.

Objectives of Identity Protection

- Protect user identities from cyber threats.
- Prevent unauthorized access to systems and data.
- Ensure only legitimate users can access resources.
- Reduce identity theft and account compromise.
- Strengthen organizational cybersecurity.

Authentication

Definition

Authentication is the process of verifying the identity of a user, device, or system before granting access to resources.

Authentication answers the question:

"Who are you?"

A user must successfully prove their identity before accessing a system.

Types of Authentication

Password-Based Authentication



The user logs in using a username and password.

Example

Logging into Gmail using an email address and password.

Biometric Authentication

Uses unique biological characteristics to verify identity.

Examples

- Fingerprint
- Face Recognition
- Iris Scan
- Voice Recognition

Smart Card Authentication

Uses a physical smart card containing digital credentials.

Examples

- Employee ID Cards
- ATM Cards
- Access Cards

Token-Based Authentication

Uses hardware or software tokens to generate one-time authentication codes.

Examples

- OTP Generator
- Security Token

Certificate-Based Authentication

Uses digital certificates issued by trusted Certificate Authorities (CA).

Examples

- SSL Certificates
- Digital Signatures

Authentication Factors

Authentication is based on one or more of the following factors:

Something You Know



- Password
- PIN
- Security Question

Something You Have

- Mobile Phone
- Smart Card
- Security Token

Something You Are

- Fingerprint
- Face Recognition
- Retina Scan
- Voice Recognition

Importance of Authentication

- Prevents unauthorized access.
- Verifies user identity.
- Protects confidential information.
- Supports secure online transactions.
- Reduces identity fraud.

Authorization

Definition

Authorization is the process of determining what an authenticated user is allowed to access or perform within a system.

Authorization answers the question:

"What are you allowed to do?"

Authentication always occurs before authorization.

Examples of Authorization

- Students can view examination results but cannot modify them.
- Faculty members can update student marks.
- HR staff can access employee salary information.
- Customers can access only their own bank accounts.

Types of Authorization



Role-Based Access Control (RBAC)

Access permissions are assigned based on user roles.

Examples

- Student
- Faculty
- Administrator
- Manager

Attribute-Based Access Control (ABAC)

Access decisions are based on user attributes, location, time, or device.

Discretionary Access Control (DAC)

The resource owner decides who can access specific resources.

Mandatory Access Control (MAC)

Access permissions are determined by security policies established by the organization.

Importance of Authorization

- Restricts access to authorized users.
- Protects sensitive information.
- Prevents accidental or intentional misuse.
- Supports compliance with security policies.

Authentication vs Authorization

Authentication	Authorization
Verifies user identity.	Determines user permissions.
Occurs before authorization.	Occurs after successful authentication.
Asks "Who are you?"	Asks "What can you access?"
Uses passwords, biometrics, or OTPs.	Defines roles, permissions, and access policies.
Example: User logs into a system.	Example: User can only access permitted files.

Password Security

Definition

Password Security refers to the practices and technologies used to create, manage, and protect passwords from unauthorized access.

Strong passwords are the first line of defence against cyber attacks.

Characteristics of a Strong Password

- Minimum 12–16 characters.
- Combination of uppercase and lowercase letters.
- Includes numbers.
- Includes special characters.
- Does not contain personal information.
- Unique for every account.

Example

Weak Password

password123

Strong Password

Cyb3r@Secure#2026

Common Password Attacks

Brute Force Attack

Attackers try every possible password combination until the correct password is found.

Dictionary Attack

Attackers use a list of commonly used passwords.

Credential Stuffing

Stolen usernames and passwords from one website are used to access other accounts.

Password Spraying

Attackers try a few common passwords across many user accounts.

Keylogging

Malicious software records keyboard input to steal passwords.

Password Security Best Practices

- Create strong and unique passwords.
- Never reuse passwords across multiple accounts.
- Change passwords periodically.
- Store passwords securely using a password manager.
- Never share passwords.
- Avoid writing passwords on paper.
- Enable Multi-Factor Authentication.
- Avoid predictable passwords such as birthdays or names.

Multi-Factor Authentication (MFA)

Definition

Multi-Factor Authentication (MFA) is a security mechanism that requires users to verify their identity using two or more independent authentication factors before gaining access to a system.

Even if one authentication factor is compromised, unauthorized access is significantly more difficult.

Authentication Factors Used in MFA

Knowledge Factor

Something the user knows.

Examples

- Password
- PIN

Possession Factor

Something the user possesses.

Examples

- Mobile Phone
- OTP
- Smart Card
- Security Token

Inherence Factor

Something unique to the user.



Examples

- Fingerprint
- Face Recognition
- Iris Scan

Examples of MFA

Online Banking

- Username and Password
- OTP sent to registered mobile number

Google Account

- Password
- Verification code from Google Authenticator

Corporate Login

- Password
- Fingerprint Authentication

ATM Transaction

- ATM Card
- PIN

Advantages of MFA

- Provides stronger authentication.
- Reduces unauthorized access.
- Protects against stolen passwords.
- Prevents identity theft.
- Enhances cybersecurity.
- Meets regulatory and compliance requirements.

Limitations of MFA

- Slightly increases login time.
- Requires additional devices or applications.
- Users may lose access if authentication devices are unavailable.
- Implementation and maintenance costs may increase.

Real-World Applications of Identity Protection

Banking



- Customers log in using passwords and OTPs.
- Biometric authentication secures mobile banking apps.

Healthcare

- Doctors authenticate using smart cards and passwords.
- Role-based authorization restricts access to patient records.

Education

- Students authenticate using university credentials.
- Faculty members receive additional permissions to upload grades.

Corporate Organizations

- Employees use MFA to access company systems.
- Administrators receive higher privileges based on job roles.

Cloud Services

- Users authenticate using passwords and authenticator applications.
- Access is controlled through Identity and Access Management (IAM) policies.

Best Practices for Identity Protection

- Use strong and unique passwords for every account.
- Enable Multi-Factor Authentication (MFA) wherever available.
- Never share passwords, OTPs, or authentication tokens.
- Use password managers to securely store credentials.
- Apply the Principle of Least Privilege (PoLP).
- Regularly review user accounts and access permissions.
- Disable inactive or unused accounts.
- Monitor login activities for suspicious behaviour.
- Keep operating systems and applications updated.
- Educate users about phishing, credential theft, and social engineering attacks.

Summary

- Identity Protection safeguards digital identities and prevents unauthorized access to systems and information.
- Authentication verifies the identity of a user before access is granted.
- Authorization determines the resources and actions an authenticated user is permitted to access.
- Password Security involves creating, managing, and protecting strong passwords to defend against common password attacks.

- Multi-Factor Authentication (MFA) enhances security by requiring two or more authentication factors, significantly reducing the risk of account compromise and identity theft.

Cryptography Fundamentals

Introduction

Cryptography is the science of protecting information by converting readable data (plaintext) into an unreadable form (ciphertext) using mathematical algorithms and cryptographic keys. Only authorized users with the correct key can convert the ciphertext back into its original form (plaintext).

Cryptography is one of the fundamental technologies used to ensure secure communication, protect sensitive information, and maintain privacy in digital systems.

Objectives of Cryptography

- Protect confidential information.
- Prevent unauthorized access to data.
- Ensure data integrity.
- Verify the identity of users.
- Support secure online communication.
- Protect financial and business transactions.

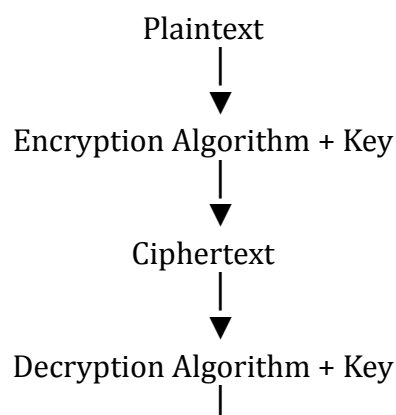
Need for Encryption

Definition

Encryption is the process of converting readable data (plaintext) into an unreadable format (ciphertext) using an encryption algorithm and a cryptographic key.

The original data can only be recovered through decryption using the appropriate key.

Encryption Process





▼
Plaintext

Why Encryption is Needed

Protect Confidential Information

Prevents unauthorized users from reading sensitive information.

Example

Encrypting customer banking information.

Secure Data Transmission

Protects data while it is transmitted over the Internet.

Example

HTTPS secures communication between users and websites.

Prevent Data Theft

Even if attackers steal encrypted data, they cannot read it without the decryption key.

Ensure Privacy

Protects personal information such as passwords, medical records, and financial data.

Meet Legal and Regulatory Requirements

Many regulations require organizations to encrypt sensitive information.

Protect Cloud Data

Encryption ensures that cloud-stored information remains secure.

Applications of Encryption

- Online Banking
- E-Commerce
- Email Security
- Cloud Storage
- Mobile Applications
- Virtual Private Networks (VPN)
- Digital Payments
- Government Systems

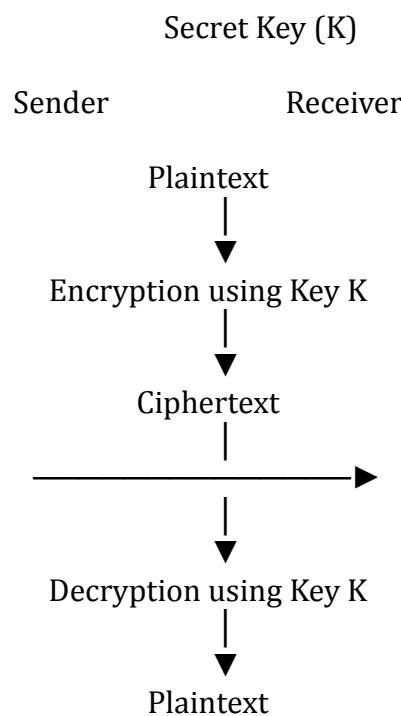
Symmetric Encryption

Definition

Symmetric Encryption is a cryptographic technique in which the same secret key is used for both encryption and decryption.

Both the sender and the receiver must possess the same secret key.

Working of Symmetric Encryption



Characteristics

- Uses one shared secret key.
- Fast encryption and decryption.
- Suitable for encrypting large amounts of data.
- Requires secure key distribution.
- Less computationally expensive.

Advantages

- High speed.
- Efficient for large files.
- Simple implementation.
- Low computational overhead.

Limitations

- Secure key sharing is difficult.
- If the key is compromised, all encrypted data is exposed.
- Not ideal for communication over untrusted networks.

Common Symmetric Encryption Algorithms

- AES (Advanced Encryption Standard)
- DES (Data Encryption Standard)
- Triple DES (3DES)
- Blowfish
- Twofish

Real-World Applications

- Disk Encryption
- Database Encryption
- Wi-Fi Security (WPA2/WPA3)
- VPN Communication
- File Encryption

Asymmetric Encryption

Definition

Asymmetric Encryption is a cryptographic technique that uses two mathematically related keys:

- Public Key
- Private Key

The Public Key encrypts data, while the Private Key decrypts it.

Working of Asymmetric Encryption

Sender

Receiver

Plaintext



Encrypt using Receiver's
Public Key



Ciphertext



Decrypt using Receiver's
Private Key



Plaintext

Characteristics

- Uses two different keys.
- Public key can be shared openly.
- Private key is kept secret.
- More secure for communication over public networks.
- Slower than symmetric encryption.

Advantages

- Secure key distribution.
- Supports digital signatures.
- Provides authentication.
- Suitable for Internet communication.

Limitations

- Slower than symmetric encryption.
- Higher computational cost.
- Less efficient for encrypting large files.

Common Asymmetric Algorithms

- RSA
- ECC (Elliptic Curve Cryptography)
- Diffie–Hellman (Key Exchange)
- ElGamal

Real-World Applications

- HTTPS Websites
- Secure Email
- SSL/TLS Certificates
- Online Banking
- Digital Certificates
- VPN Authentication

Comparison: Symmetric vs Asymmetric Encryption

Feature	Symmetric Encryption	Asymmetric Encryption
Number of Keys	One Secret Key	Two Keys (Public & Private)
Encryption Speed	Fast	Slower
Security	Depends on key secrecy	Higher due to separate keys
Key Distribution	Difficult	Easy using Public Key
Best Used For	Large data encryption	Secure key exchange and authentication
Examples	AES, DES, Blowfish	RSA, ECC, ElGamal

Digital Signatures

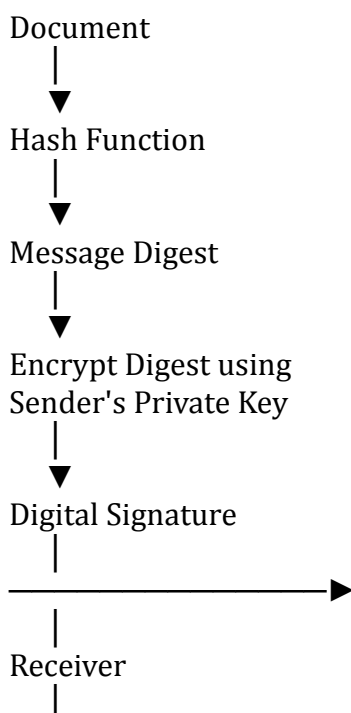
Definition

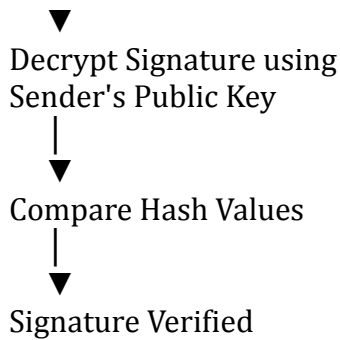
A Digital Signature is a cryptographic technique used to verify the authenticity, integrity, and non-repudiation of digital documents or messages.

A digital signature is created using the sender's Private Key and verified using the sender's Public Key.

Working of Digital Signature

Sender





Objectives of Digital Signatures

- Verify sender identity.
- Ensure message integrity.
- Prevent message tampering.
- Provide non-repudiation.
- Build trust in electronic transactions.

Advantages

- High security.
- Protects document integrity.
- Verifies sender authenticity.
- Legally accepted in many countries.
- Prevents forgery.

Limitations

- Requires Public Key Infrastructure (PKI).
- Certificate management is necessary.
- More computationally intensive than simple authentication methods.

Applications of Digital Signatures

- E-Governance
- Income Tax Filing
- Online Banking
- Software Distribution
- Legal Documents
- Electronic Contracts
- Digital Certificates

Real-World Applications of Cryptography

Banking



- AES encrypts customer account information.
- RSA secures online banking sessions.
- Digital signatures verify electronic transactions.

E-Commerce

- HTTPS encrypts customer payment details.
- Digital certificates authenticate websites.

Healthcare

- Patient records are encrypted before storage.
- Digital signatures authenticate electronic prescriptions.

Cloud Computing

- Files stored in the cloud are encrypted.
- Users authenticate using secure cryptographic protocols.

Government

- Digital signatures authenticate official documents.
- Encrypted communication protects classified information.

Best Practices for Cryptography

- Use strong encryption algorithms such as AES-256.
- Protect cryptographic keys from unauthorized access.
- Regularly rotate and manage encryption keys.
- Use RSA or ECC for secure key exchange.
- Implement digital signatures for authentication and integrity.
- Use HTTPS/TLS for secure web communication.
- Keep cryptographic software updated.
- Never share private keys with unauthorized individuals.
- Use hardware security modules (HSMs) for secure key storage where appropriate.